MITRE ATT&CK TTPs Capa-rule을 활용한 앙상블 기반 공급망 보안 강화형 악성코드 탐지

김나연* 김상훈** 오태호*** 이시언**** 임나현***** 허라영******

*강원대학교 전자공학과

**울산대학교 IT융합전공

***KITRI 화이트햇 스쿨

****대구가톨릭대학교 컴퓨터소프트웨어학부

*****울산대학교 AI융합전공

******건국대학교 컴퓨터공학부

Ensemble-Based Malware Detection for Supply Chain Security Using Capa-rule with MITRE ATT&CK TTPs

Na-Yeon Kim* Sang-Hoon Kim** Tae-Ho OH*** Si-Eon Lee**** Na-Hyun Lim***** Ra-Yeong Hur******

*Dept, of Electronics Engineering, Kangwon National University

**Dept, of IT Convergence, University Of Ulsan

***KITRI WhiteHat School

****Dept, of Computer Software, Daegu Catholic University

*****Dept, of AI Convergence, University Of Ulsan

******Dept, of Computer Science & Engineering, ,Konkuk University

요 약

최근 몇 년간 공급망을 노린 악성코드 공격이 증가하면서, 시그니처 기반 탐지법의 한계가 실질적으로 드러난 사례가 보고되고 있다. 본 논문에서는 정적 분석 도구인 Capa-rule을 활용하여 실행 파일로부터 MITRE ATT&CK·MBC 분류 체계에 따른 행위 기반 피처를 추출하고, 이를 머신러닝 및 딥러닝 모델의 학습 데이터로 활용하였다. 또한, Stacking 앙상블 기법을 통해 모델을 결합하여, 단일 모델 대비 앙상블 모델의 탐지 성능이 향상됨을 실험적으로 입증하였다.

I. 서론

2015년과 2016년 우크라이나 전력망 공격 사례와 같이, 악성코드는 사회 기반시설에 직접적인 피해를 초래할 수 있다[1]. 또한, 최근에는 IT 공급망을 겨냥한 공격도 지속적으로 증가하고 있어, 고도화된 악성코드 탐지 체계의 도입이 요구된다[2]. 그러나 기존 시그니처 기반 탐지 방식은 새로운 악성코드나 제로데이 위협에 효과적으로 대응하지 못한다는 한계가 있다.

본 논문은 이러한 문제를 극복하기 위해 Capa-rule을 활용해 행위 기반 피처를 추출하고, 이를 머신러닝과 딥러닝 모델의 학습에 활용한 후, 앙상블 기법을 적용하여 탐지 성능을 향상시키는 방안을 제시한다.

II. 배경 지식

2.1 Capa-rule 기반 정적 분석

CAPA란 최신 공격 기법에 대응할 수 있도록 지속적으로 업데이트되는 정적 분석 오픈 소스 도구이다. 본 논문에서는 CAPA를 활용해 PE 파일 내 악성 행위를 MITRE ATT&CK 및 MBC 분류 체계에 따라 자동으로 태깅하고, 이를 기능 단위로 구조화하여 악성 여부를 판별하는 이진 분류 모델의 입력 피처로 활용하였다.

2.2 딥러닝 및 앙상블 기법

딥러닝이란 인공신경망에 기반을 둔 일련의 Machine Learning의 집합체로, 자동으로 특징 간의 복잡한 상호작용을 탐지하여 높은 예측 성능을

[표 1] 전처리 방식에 따른 데이터셋 구성

Num	Entropy	ATT&CK	MBC	Namespace	capability	Accuracy
Dataset1	원본값 유지	One-Hot Encoding		수량 정보 추출		0.9453
Dataset2	원본값 유지	One-Hot Encoding + PCA		수량 정보 추출 + PCA		0.9465
Dataset3	원본값 유지	One-Hot Encoding + PCA		수량 정보 추출	수량 정보 추출 + PCA	0.9479
Dataset4	원본값 유지	One-Hot Encoding + 일부 PCA		수량 정보 추출	수량 정보 추출 + PCA	0.9475

달성할 수 있다[3]. 본 논문에서는 1D-CNN(지역적 패턴 학습)과 MLP(전역적 패턴 학습) 구조의 딥러닝 모델을 설계하였다.

또한, 앙상블 기법 중 하나인 Stacking은 여러 모델의 예측 결과를 조합해 메타 모델이 최종 예측을 수행하는 방식으로, 본 논문에서는 이를 활용해 딥러닝과 머신러닝 모델을 결합하였다.

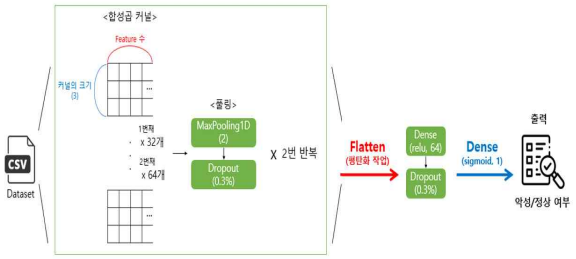
III. 머신러닝과 딥러닝 기반의 악성코드 탐지 방법

3.1 데이터 수집 및 전처리 방법

본 논문에서는 악성코드 탐지를 위한 머신러닝 및 딥러닝 모델 학습을 위해 총 96,161개의 실행 파일(정상 43,455개, 악성 52,706개)을 수집하였다. 정상 데이터는 KISA 보호나라, Windows 기본 파일, 국내외 공인 소프트웨어 등에서, 악성 데이터는 KISA 사이버 보안 빅데이터 센터와 Malware Bazaar 등에서 확보하였다. 수집된 실행 파일은 CAPA 분석을 통해 ATT&CK Tactic(공격 전략), ATT&CK Technique(공격 기술), MBC Objective(목적), MBC Behavior(행동 유형), Namespace(기능 분류), Capability(기능 역량)의 6가지 필드 값으로 나타냈다. 각 파일 내 바이트 분포의 무작위성을 측정하는 지표로, 압축되거나 암호화된 악성코드에서 높은 값을 보이는 경향이 있는 엔트로피(Entropy) 값도 하나의 필드로 포함하였다.

추출된 7가지의 필드를 토대로, AI에 학습시킬 수 있도록 각 실행 파일을 csv파일로 변환했으며, 전처리 과정을 거쳐 [표 1]과 같이 4가지의 각기 다른 데이터셋을 만들었다.

Capability와 Namespace 항목은 각각 전체 수량 정보 및 최상위 디렉토리를 기준으로 범주화하여 수량을 나타내었으며, 수치화가 불가능한 범주형 feature는 범주 간 독립성을 보장하기 위해 One-Hot Encoding을 적용하였다. One-Hot Encoding으로 인한 feature 수 급증을 해결하기 위해 PCA 기법을 일부 범주형 feature에 적용하였고, 피어슨 상관 계수를 계산하여 악성/정상 여부와 상관계수가 0.05 이하인 feature를 제거하였다.



[그림 1] 1D-CNN 모델 설계도

최종적으로 Dataset1~Dataset4를 구성하여 성능을 비교한 결과, 가장 높은 Accuracy를 가진 Dataset3을 최종 학습용 데이터셋으로 선정하였다.

3.2 머신러닝 모델 설계

본 논문에서는 머신러닝 모델 설계를 위해 Random Forest, XGBoost, LightGBM, CatBoost의 4개의 알고리즘을 활용하였다.

Random Forest는 과적합을 줄이고 예측의 안정성을 높이는 데 효과적이며, XGBoost와 LightGBM은 부스팅 계열 알고리즘으로 높은 정확도를 보인다. 특히 LGBM은 빠른 학습 속도를 제공하고, CatBoost는 범주형 변수를 자동으로 처리할 수 있어 이러한 특성이 많은 데이터셋에서 유용하게 활용될 수 있다.

또한, 하이퍼 파라미터 튜닝 방식으로 기대 개선을 기준으로 최적 조합을 탐색하는 방식인 베이지안 최적화(Bayesian Optimization)와 파라미터에 대해 사용자가 지정한 모든 가능한 조합을 탐색하는 방식인 그리드 서치(Grid Search)를 사용하였다.

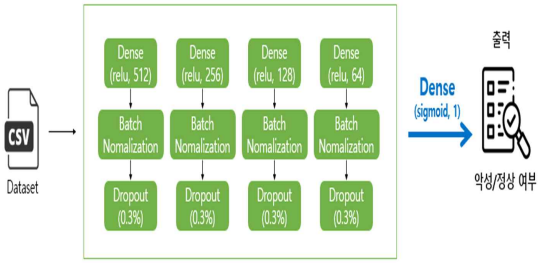
XGBoost, CatBoost와 같이 학습 시간이 긴 모델에 대해 베이지안 최적화를 적용하고, 이외 모델에 그리드 서치를 적용함으로써 효율적으로 최적 파라미터를 찾아 모델 제작에 성공하였다.

3.3 딥러닝 모델 설계 및 앙상블 구성

본 논문에서 설계한 딥러닝 모델은 총 두 가지로, 각각 1D-CNN과 MLP 구조로 설계하였으며, [그림 1]과 [그림 2]는 각각 본 논문에서 구현한

[표 2] 머신러닝 모델 평가 결과

Model	Accuracy	Precision	Recall	F1-score
XGBoost	0.9465	0.9453	0.9395	0.9413
LightGBM	0.9503	0.9472	0.9438	0.9455
Random Forest	0.9459	0.9489	0.9318	0.9413
CatBoost	0.9439	0.9465	0.9414	0.9439



[그림 2] MLP 모델 설계도

각 모델의 설계도를 나타낸다.

이 중 Dropout Layer는 학습 시 뉴런의 일부를 무작위로 비활성화하는 부분으로, 모델의 과적합을 방지하고 일반화 성능을 높인다. 각 모델에는 Dropout Layer를 추가하여 과적합을 방지하였고, MLP 모델의 각 Layer 사이에 Batch Nomalization를 넣어 학습 도중 활성 값의 분포가 지나치게 바뀌는 것을 막았다.

최종적으로 앞서 설계한 머신러닝 및 딥러닝 모델을 Stacking 방식으로 앙상블하여 하나의 탐지 모델로 제작하였다. 제작 시에는 LightGBM+CNN, LightGBM+MLP, LightGBM+CNN+MLP의 여러 조합을 구성하여 탐지 성능을 비교하였다.

IV. 평가 결과 및 분석

4.1 평가 지표 정의

본 논문에서는 모델의 성능을 평가하기 위해 정확도(Accuracy), 정밀도(Precision), 재현율(Recall), F1-score 네 가지 지표를 사용하였다.

정확도는 전체 샘플 중에서 올바르게 분류된 샘플의 비율을 의미하며, 정밀도는 악성으로 예측한 샘플 중 실제 악성인 샘플의 비율을 나타낸다. 재현율은 실제 악성 샘플 중에서 악성으로 올바르게 예측된 비율을 의미하고, F1-score는 정밀도와 재현율의 조화 평균으로, 두 지표의 균형을 종합적으로 고려한 지표이다.

4.2 머신러닝 모델 성능

[표 2]는 머신러닝 기반 모델의 성능을 비교한 결과이다. 그 중 LightGBM 모델은 정확도 95.03%, 정밀도 94.72%, 재현율 94.38%, F1-score 94.55%를 기록하여, 다른 머신러닝 모델 대비 가장 우수한 성능을 보였다.

4.3 딥러닝 및 앙상블 모델 성능

[표 3]은 딥러닝 및 앙상블 모델의 정확도를 비교한 결과이다. 단독 딥러닝 모델인 MLP와 CNN은 각각 87.96%, 90.3%로 머신러닝보다 낮은 정확도를 보였으나, LightGBM과의 앙상블을 통해 성능이 크게 개선되었다. 특히 LightGBM+CNN 모델은 95.48%의 정확도를 기록하며, 전체 모델 중 가장 우수한 성능을 보였다.

[표 3] 딥러닝 및 앙상블 모델 평가 결과

Model	Accuracy
LightGBM	0.9503
MLP	0.8796
CNN	0.903
LightGBM + MLP	0.9506
LightGBM + CNN	0.9548
LightGBM + CNN + MLP	0.9507

4.4 앙상블 효과 및 성능 향상 분석

머신러닝 단독 모델인 LightGBM은 높은 정확도를 보였으나, 훈련 데이터에 일부 과적합되는 경향이 관찰되었다. 이러한 한계는 CNN 모델과의 앙상블을 통해 보완되었으며, 두 모델의 예측 확률 값을 메타 모델에 입력하여 구성한 앙상블 모델은 기존보다 0.45% 향상된 95.48%의 정확도를 달성하였다.

이러한 결과는 스태킹 기반의 앙상블 기법이 단일 모델의 한계를 보완하고, 탐지 정확도와 안정성을 함께 향상시킬 수 있음을 시사한다.

V. 결론

공급망을 겨냥한 악성코드 공격이 정교해짐에 따라, 전통적인 시그니처 기반 탐지 방식만으로는 이러한 새로운 위협에 효과적으로 대응하기 어렵다. 이를 해결하기 위해, 본 논문에서는 Capa-rule과 MITRE ATT&CK·MBC 정보를 활용하여 머신러닝과 딥러닝 모델에 학습을 수행함으로써, 기존 방식의 한계를 보완할 수 있는 탐지 모델을 개발하였다.

또한, 단일 모델 기반 접근에서 생기는 각 모델별 한계를 극복하기 위해, 기존 악성코드 탐지 분야에서 드물게 시도된 머신러닝-딥러닝 기반의 Stacking 앙상블 기법을 적용하여, 단일 모델 대비 탐지 성능의 향상을 실험적으로 입증하였다.

결론적으로, 본 논문은 악성코드 탐지 모델 설계에 있어 행위 기반 피처와 앙상블 기법의 결합이 유효한 방법론임을 제시하였으며, 실제 사이버 보안 시스템에 적용될 가능성이 있음을 보여주었다.

[참고문헌]

[1] 권혁, “전력망 사이버 재난과 자연재난, 사이버 리질리언스에 대한 고찰”, 전기의세계, 제71권 제2호, 쪽 24-28, 2022.

[2] 서영희, “국방 SW 공급망 보안 강화를 위한 발전방향 연구”, KIIT 학술대회 논문집, 제주, 2024년 11월.

[3] 박재운, “API 특징을 이용한 Deep Learning 기반 악성코드 탐지”, 석사학위논문, 건국대학교 대학원, 2017.